

10 scénarios d'attaque web

Rappel : pour chaque scénario le stagiaire doit rendre **1 page max** contenant — dans cet ordre strict — *Nom de la vulnérabilité OWASP (1 ligne)*, *Justification (1–2 lignes)*, *Steps d'exploitation / PoC (5–8 lignes)*, *Impact potentiel*, *Prévention — checklist (2 techniques + 2 organisationnelles + tests à automatiser)*, *Score de risque + 2 recommandations prioritaires*, *Temps passé*.

Niveau BASIC (3 scénarios)

Scénario 1

Contexte : la valeur du paramètre `q` est insérée telle quelle dans la page HTML des résultats (aucun échappement côté serveur).

Scénario 2

Contexte : la requête SQL est construite par concaténation des champs `username` et `password` fournis par l'utilisateur.

Scénario 3

Contexte : les ressources sont servies via `GET /invoices/{id}` et l'application n'effectue pas de vérification que l'ID appartient à l'utilisateur connecté.

Niveau MEDIUM (3 scénarios)

Scénario 4

Contexte : action POST qui transfère des crédits vers un bénéficiaire sans token anti-CSRF ; cookie de session envoyé automatiquement par le navigateur.

Scénario 5

Contexte : pas de rate-limiting, pas de verrouillage adaptatif, pas de MFA ; les tentatives de connexion ne sont pas surveillées.

Scénario 6

Contexte : l'application télécharge et renvoie le contenu d'une URL fournie par l'utilisateur sans valider l'hôte ni la plage d'IP (possibilité d'atteindre l'intranet).

Niveau ADVANCED (4 scénarios)

Scénario 7

Contexte : l'application reçoit un objet sérialisé (ex. Java/PHP) depuis le client et le désérialise sans validation ni restriction.

Scénario 8

Contexte : upload d'images autorisé vers un répertoire accessible publiquement ; une inclusion locale vulnérable existe ailleurs dans l'app.

Scénario 9

Contexte : l'application rend du contenu utilisateur via le moteur de templates côté serveur (ex. Jinja/Twig) et autorise des éléments interprétables par le template engine.

Scénario 10

Contexte : pipeline CI récupère automatiquement des dépendances externes non verrouillées ; un paquet malveillant/compromis peut être intégré dans la build.